

The Agency for the Protection of Personal Data has imposed an administrative monetary fine on the data controller, Zagrebački holding d.o.o., in the amount of 25,000.00 euros (188,362.50 kuna) due to the following established violations of the General Data Protection Regulation:

1. The data controller did not adequately inform service users about the legal basis for the processing of personal data and the retention period of personal data when collecting a copy of the personal identification document for the purpose of issuing a copy of the bill via email, thereby acting contrary to the provisions of Article 13, paragraph 1 (c) and Article 13, paragraph 2 (a), (e) of the General Data Protection Regulation. According to the aforementioned provisions, if personal data is collected from the data subject, the data controller is obliged to provide the data subjects with all information regarding the processing of their personal data at the time of collection (for example, informing them about the purpose and legal basis for the processing of personal data, the period during which personal data will be stored, etc.) in a concise, understandable, and easily accessible form, using clear and plain language.
2. The data controller did not take appropriate technical and organizational measures when processing personal data for the purpose of identifying service users for the issuance of a copy of the bill via email, thereby violating the provisions of Article 25, paragraph 2 of the General Data Protection Regulation.

Specifically, the Agency for the Protection of Personal Data received a submission from a citizen stating that Zagrebački holding d.o.o. requests a copy of the personal identification card from service users before issuing a copy of the bill (water management fee and utility fee) via email. It was also stated that for the same service, identification previously required only the provision of name, surname, address, personal identification number (OIB), system number of the object, and system number of the taxpayer.

The procedure established that the data controller does not have prescribed rules for the identification of service users requesting the delivery of a copy of the bill via electronic mail and that it collected copies of users' identification documents via email only in cases of suspicion of false representation. Specifically, Zagrebački holding requested a copy of the personal identification document from users who used an email address that has a different name/title from the name and surname of the service user, i.e., if the name and surname of the service user who requested the copy of the bill via email did not match the structure of the email address from which the request for the copy of the bill was made. The mere construction of the email address containing the appropriate name and surname is not a protective measure that would provide the data controller with sufficient assurance that the request was made by the actual service user. Consequently, it was established that the data controller failed to implement appropriate technical and organizational measures for protection or to organize the processing procedure for the purpose of identifying service users who requested a copy of the bill via email, thereby acting contrary to Article 25, paragraph 2 of the General Data Protection Regulation.

The data controller should have developed business processes for identification via electronic mail in a manner that ensures that the identification process for service users is the same for all users, regardless of the structure of the email. This procedure prevented service users, who do not have their name and surname in the structure of their email address, from communicating remotely without providing a personal identification document, i.e., from requesting a copy of the bill via email.

Additionally, this method of identification resulted in insecure processing in the form of collecting copies of personal identification documents, during which a feeling of loss of control over their personal data was created among the respondents from whom the identification document was requested without providing all relevant information.

The data controller also failed to transparently inform service users about the legal basis for collecting personal data (copies of personal identification cards) for identification purposes. The relevant information was not available to the respondents either through published documents related to the processing of personal data on the official websites of the data controller or after the respondents directly requested information about the processing via email, which is contrary to the provisions of

Article 13, paragraph 1 (c) and Article 13, paragraph 2 (a), (e) of the General Data Protection Regulation.